PRATIK SANJAY KHAIRNAR

Certified Ethical Hacker (CEH v13) | Associate Penetration Tester & Web VAPT Engineer

Pune, Maharashtra, India • +91 87999 81052 • pratik.khairnar.sec@gmail.com • linkedin.com/in/pratik-khairnar-sec • github.com/pratik-khairnar-sec

PROFESSIONAL SUMMARY

Certified Ethical Hacker (CEH v13) pursuing B.Tech in Cyber Security & Forensics (2023–2027) with operational experience in manual Web Application Penetration Testing (Web VAPT), REST API authorization testing (BOLA / IDOR), and custom offensive security tooling. Demonstrated track record executing vulnerability assessments at GROOTT Services and investigating 15+ live cybercrime cases at the Cyber Police Station, Nashik Police Commissionerate. Testing strictly aligned with OWASP Top 10 (2021), OWASP API Security Top 10 (2023), OWASP WSTG v4.2, and ASVS v4.0 methodologies, delivering actionable CVSS v3.1 reports with verified Proof-of-Concepts (PoCs) and developer-ready remediation roadmaps.

CORE TECHNICAL COMPETENCIES

Application Security & VAPT: Manual Web VAPT, OWASP Top 10 (2021), OWASP API Top 10 (2023), Broken Object Level Authorization (BOLA/IDOR), Broken Function Level Authorization (BFLA), Business Logic Flaws, Authentication Bypasses (OAuth 2.0 / JWT), Privilege Escalation, SQL Injection (Blind Time/Boolean), Cross-Site Scripting (DOM/Reflected XSS), SSRF, CORS Misconfigurations.

Methodologies & Frameworks: OWASP WSTG v4.2, OWASP ASVS v4.0, SANS Top 25, NIST SP 800-115, CVSS v3.1 Severity Scoring, Threat Modeling, Secure SDLC (SSDLC) Principles, Remediation Verification & Closure Retesting.

Security Tools & Arsenal: Burp Suite Professional (Intruder, Repeater, Sequencer, Extension APIs), Postman, Nmap, Wireshark, SQLMap, OWASP ZAP, Git, Linux / Kali Linux CLI, Headless Chrome Automation.

Scripting & Automation: Python 3 (Requests, Regex, Custom PoC Automation), Bash Scripting, Java 17/21 (Burp Extension Architecture), JavaScript / DOM Analysis.

Digital Forensics & Law Enf.: Evidence Chain of Custody Protocols, CDR / IPDR Telecom Forensics, Android APK Malware Triage, Indicator of Compromise (IOC) Analysis, PCAP Traffic Dissection, CERT-In Reporting Standards.

PROFESSIONAL EXPERIENCE

Cyber Crime Intern — Cyber Police Station, Nashik Police Commissionerate **Jan 2026 – May 2026**

- Investigated 15+ live cybercrime and digital fraud cases in direct collaboration with cyber cell officers, strictly adhering to legal evidence Chain of Custody protocols.
- Performed deep packet-level network traffic analysis using Wireshark to reconstruct malicious communication sessions and trace active attack infrastructure.
- Analyzed suspicious Android APK packages, correlated CDR/IPDR telecom intelligence, and isolated high-fidelity Indicators of Compromise (IOCs) to support formal evidentiary proceedings.

Junior Penetration Tester — GROOTT Services **Jun 2025 – Oct 2025**

- Executed end-to-end manual Web Application Penetration Testing (Web VAPT) and REST API security audits across multi-tenant environments benchmarked against OWASP Top 10 (2021) and WSTG v4.2 standards.
- Identified critical vulnerability classes including Broken Object Level Authorization (BOLA / IDOR), OAuth 2.0 authentication bypasses, JWT signature manipulation, and Boolean Blind SQLi.
- Authored technical and executive-ready VAPT documentation featuring CVSS v3.1 severity ratings, defensible Proof-of-Concepts (PoCs), and pragmatic developer remediation roadmaps.
- Conducted post-remediation closure retesting alongside engineering teams, validating root-cause vulnerability resolution prior to production release.

OFFENSIVE SECURITY PROJECTS & TOOLING

AUTHENTIX Enterprise v2.1.0 — Burp Suite Extension | Java 17/21 | BOLA/IDOR Testing

- Native Burp Suite extension for automated authorization (BOLA/IDOR) testing, session validation, and token replay verification. Analyzes multi-tenant API endpoints in real time with verifiable reproduction logs.

ReconForge v3 — OSINT Framework | 52,600+ Dork Vault | 30 Master Phases

- Client-side Bug Bounty reconnaissance workspace featuring 30 structured target phases and 52,630+ curated dorks. Automates asset triage, attack surface mapping, and tool-major CLI syntax pipelines executing 100% locally with zero cloud leakage.

Reflectra v7.0.0 — Context-Aware DOM XSS Engine | Python 3 | Headless Chrome

- High-accuracy Cross-Site Scripting scanner evaluating 2,600+ context-prioritized payloads across HTML, attribute, and JS execution contexts. Validates genuine exploitability via automated headless browser dialog evaluation with zero false positives.

BlindStrike v7.0.0 — Statistical Blind SQLi Framework | Python 3 | Multi-DB Support

- Empirical latency calibration framework for Time-Based and Boolean Blind SQL Injection. Implements Interquartile Range (IQR) network variance filtering and multi-threaded extraction across multi-database environments.

CORSair v3.0.0 — CORS Misconfiguration Auditor | Shannon Entropy | PoC Suite

- Dynamic origin reflection scanner evaluating ACAO/ACAC header misconfigurations, credential exposure, Shannon entropy token leakage, and automated exploit PoC generation.

EDUCATION

B.Tech in Computer Science & Engineering (Cyber Security & Forensics) **2023 – 2027**

Sandip University, Nashik, Maharashtra • CGPA: 7.42 / 10

Relevant Coursework: Application Security (VAPT), Secure Software Development Lifecycle (SSDLC), Network Defense, Cryptography, Reverse Engineering, Digital Forensics, Linux Operating Systems.

CERTIFICATIONS & CREDENTIALS

- **Certified Ethical Hacker (CEH v13)** — EC-Council • Credential Verification Exam ID: ECC8042517936
- **Cisco Certified Network Associate (CCNA)** — Cisco Networking Academy